

Univerzitet u Beogradu
Matematički fakultet

Računarstvo i društvo

Ofanzivna bezbednost i pentesting
Seminarski rad

Student: Katarina Grbović(257/2019)

Profesor: Dr. Sana Stojanović Durdević

Novembar 2025

Sadržaj

1	Uvod	3
1.1	Razlika između ofanzivne i defanzivne bezbednosti	3
1.2	Pentesting	3
2	Tipovi i metodologije u penetracionom testiranju	4
2.1	Tipovi pentestinga	4
2.1.1	Podela prema cilju testiranja	4
2.1.2	Podela prema količini informacija prilikom testiranja	5
2.2	Metodologije pentestinga	5
2.2.1	Penetration Testing Execution Standard	5
2.2.2	NIST SP 800 115: The Enterprise and Compliance Standard	6
2.2.3	Open Source Security Testing Methodology Manual	6
2.2.4	Open Web Application Security Project	7
3	Alati korišćeni u penetracionom testiranju i eskalacija privilegija	7
3.1	Alati korišćeni u penetracionom testiranju	7
3.2	Eskalacija privilegija	8
4	Zakonski i etički aspekti	10
4.1	Etički aspekti pentestinga	10
4.2	Legalni aspekti pentestinga	11
5	Trendovi i budućnost ofanzivne bezbednosti	12
5.1	Purple teaming	12
5.2	AI u pentesting napadima i odbrani	12
6	Zaključak	14

1 Uvod

Ofanzivna bezbednost (eng. *Offensive security* - **OffSec**) predstavlja niz bezbednosnih rešenja koja koriste iste taktike kao zlonamerni akteri u stvarnim napadima, ali sa ciljem da se ojača mrežna bezbednost umesto da joj se naškodi. Metode ofanzivne bezbednosti uključuju *red teaming*, *penetration testing* i *vulnerability assesment*.

Operacije u okviru ofanzivne bezbednosti izvršavaju *etički hakeri* odnosno eksperti informacione bezbednosti koji koriste veštine hakovanja kako bi pronašli i popravili IT sistemske mane. Etički hakeri uz prethodne dozvole izvršavaju simulirane napade na dati sistem, za razliku od stvarnih sajber kriminalaca koji upadaju u sisteme zarad krađe osjetljivih podataka ili pak ostavljanja malvera [9].

U okviru ofanzivne bezbednosti, *red team* [20] predstavlja grupu stručnjaka u okviru informacione bezbednosti čija je uloga da se pretvaraju da su napadač sistema kako bi testirali bezbednosne mere tog sistema. Crveni timovi izvršavaju *live fire* vežbe kako bi pomogli organizacijama da bolje razumeju potencijalne napade i kako da ih ubuduće spreče.

Defanzivna bezbednost (eng. *Defensive security*) takođe predstavlja niz bezbednosnih praksi i rešenja koja za cilj imaju zaštitu sistema, mreža i podataka od sajber pretnji i napada kroz prevenciju, detekciju i odgovor.

U odnosu na crveni tim, *blue team* [20] čini grupa sajbersekjuriti eksperata čiji je osnovni zadatak da štite sistem od spoljašnjih napada.

1.1 Razlika između ofanzivne i defanzivne bezbednosti

Za razliku od ofanzivne, kod defanzivne bezbednosti se bavimo taktikama kako da detektujemo, odgovorimo i odbranimo se od napada na sistem. Defanzivna bezbednost gleda na napadača kao na protivnika od koga se treba odbraniti, dok ofanzivna bezbednost gleda kako može da iskoristi napadačeve taktike i primeni ih u svojim rešenjima. Tipični primeri defanzivne bezbednosti su anti-virus i firewall. [3]

Jedan od osnovnih zadataka stručnjaka u okviru defanzivne bezbednosti je i da razlikuju prave pretnje u odnosu na lažne uzbune. Problem se javlja jer u okviru defanzivne bezbednosti, ne postoji definisan obrazac odbrane od novih metoda, već samo od poznatih i već proučenih metoda napada.

1.2 Pentesting

Pentest (eng. *Penetration Test*) predstavlja jedan od konkretnih procesa identifikacije bezbednosnih propusta unutar ofanzivne bezbednosti. Penetracioni test je autorizovani simulirani napad (iz perspektive napadača) na sistem radi pronalaženja bezbednosnih propusta pre nego što ih napadač pronađe. Pentesting se radi ručno, i samim tim predstavlja sveobuhvatniji proces pronalaženja bezbednosnih propusta gde se takođe i smanjuje rizik od lažne uzbune. Za izvođenje pentestinga se unajmljuju specijalizovane kompanije za pentesting i ofanzivnu bezbednost uopšte. Postoje različiti tipovi pentestinga poput: pentestinga krajnjih aplikacija, pentestinga mreže i IoT (eng. *Internet Of things*) uređaja, pentesting zaposlenih...

Kako bi se pristupilo najrazličitijim tipovima informacionih sistema, postoje različiti tipovi penetracionih testova kao i metodologije koje prate penetracione testove.

Različiti tipovi i metodologije penetracionih testova postoje kako bi se obezbedilo da procene bezbednosti budu sistematske, ponovljive i prilagođene specifičnim rizicima organizacije.

Klasifikovanjem testova i praćenjem utvrđenih pristupa, tester i mogu efikasnije otkriti ranjivosti i pružiti praktične smernice za njihovo otklanjanje.

2 Tipovi i metodologije u penetracionom testiranju

2.1 Tipovi pentestinga

Pre nego što kompanija izabere provajdera bitno je biti upućen u tipove bezbednosnih tipova pentestinga. Oni se razlikuju po stavkama na koje se fokusiraju, dubini testiranja i trajanju.

2.1.1 Podela prema cilju testiranja

- **Interni i eksterni mrežni pentesting** - procenjuje se infrastruktura mreže u kompaniji i u oblaku. Ovo podrazumeva firewall-ove, serverske sisteme i uređaje koji učestvuju. Interno testiranje se bazira na interne resurse u kompaniji. Eksterno testiranje je testiranje infrastrukture izložene internetu. Za ovaj test je neophodno poznavanje broja internih i eksternih IP adresa, veličinu subnet-a i lokacije. [9]
- **Pentestih bežičnih mreža** - ovo je testiranje WAN-a i bežičnih protokola (npr. Bluetooth, ZigBee). Cilj je otkrivanje lažnih pristupnih tačaka, slabosti enkripcije i ranjivosti WPA protokola. Neophodno je poznavanje broja bežičnih i mreža za goste, lokacije i jedinstvene SSID-eve.
- **Pentesting web aplikacija** - otkrivaju se greške u kodiranju, dizajnu i razvoju kod web sajtova i aplikacija povezanih na internet. Potrebno je znati broj aplikacija koje je neophodno testirati, broj statičkih i dinamičkih stranica i ulaznih polja.
- **Pentesting mobilnih aplikacija** - testiranje i proučavanje različitih komponenti mobilne aplikacije koje mogu otkriti potencijalne bezbednosne propuste u izvornom kodu same mobilne aplikacije
- **Build i konfiguracija sistema** - da bi se utvrdili propusti u konfiguraciji kroz web servere, aplikacione servere, rutere i firewall. Poznavanje sistemskih build-ova, operativnih sistema i koji aplikacioni serveri treba da se testiraju.
- **Socijalni inženjering** - da li sistem ima mogućnost i odgovarajući tim da detektuje i odgovori na phishing napade koji se dešavaju preko email-a. Analize se vrše kroz inicirane phishing napade, spear phishing i BEC napade.
- **Pentesting cloud-a** - pentesting klada podrazumeva sistematični proces identifikovanja i zloupotrebljavanja bezbednosnih propusta u kladu okruženjima, koja zbog

unikatne arhitekture, deljene odgovornosti i dinamičke prirode zahtevaju poseban proces testiranja.

- **Agilni pentesting** - agilni pentesting dostavlja brze i precizne bezbednosne uviđaje koji ne remete brzi tempo koji zahtevaju Agile i DevOps okruženja[17].

2.1.2 Podela prema količini informacija prilikom testiranja

Klijent definiše količinu poznatih informacija koje će podeliti sa penetracionim testerom pre samog testa, u zavisnosti od cilja penetracionog testa. Shodno tome, definišemo sledeću podelu:

- **Black box** - tester nema interne informacije o sistemu i u potpunosti simulira spoljnog napadača.
- **Gray box** - tester ima delimične informacije o sistemu poput osnovnih tehničkih detalja, korisničkih naloga itd.
- **White box** - tester ima kompletan uvid u sistem, uključujući izvorni kod, mrežnu arhitekturu, arhitekturu sistema i slično. [17]

2.2 Metodologije pentestinga

Pentesting metodologije predstavljaju formalan plan koji definiše različite faze i pravila koja osiguravaju da je penetracioni test siguran, ponovljiv i efektivan.

2.2.1 Penetration Testing Execution Standard

PTES (*eng. Penetration Testing Execution Standard*) je sveobuhvatan okvir rada za izvođenje penetracionih testova.

Osmišljen je od strane stručnjaka u oblasti informacione bezbednosti i sastoji se od sedam glavnih koraka koji pokrivaju sve aspekte pentestinga. Svrha PTES-a je da pruži tehnička uputstva kojima se definiše šta organizacije mogu očekivati od penetracionog testa. Fokus je na praktičnom toku rada koji ima za cilj da oponaša kako se stvarni sajber napadi dešavaju [10].

Faze pentestinga definisane od strane PTES-a su:

- **Priprema i pristanak** - početna faza planiranja u kojoj klijent i test tim definišu obim, ciljeve i pravila angažovanja, čime se obezbeđuje usklađenost sa zakonskim i etičkim standardima.
- **Prikupljanje informacija** - prikupljaju se sve javno dostupne informacije o meti bez da se još uvek napadaju njihovi sistemi.
- **Modelovanja pretnje** - na osnovu prikupljenih informacija modeluju se mogući vidovi napada na metu i napad se fokusira na potencijalne propuste koji predstavljaju realne poslovne rizike.
- **Analiza ranjivosti** - ova faza definiše proces otkrivanja ranjivosti u sistemu koje mogu da se iskorsite od strane napadača.

- **Eksploatacija** - uloga ove faze je da se pristupi sistemu i li resursima zaobilaznjem bezbednosnih ograničenja. Uzima se u obzir verovatnoća uspeha i ovo nosi najveći uticaj.
- **Post-eksploatacija** - ova faza predstavlja održavanje dobijenog pristupa ranjivog sistema i prikupljaju se podaci sa istog.
- **Izveštavanje** - dostavlja se završni izveštaji sa netehničkim izvršnim sažetkom i detaljnim tehničkim izveštajem [16] [6].

2.2.2 NIST SP 800 115: The Enterprise and Compliance Standard

Za razliku od PTES metodologije čiji je fokus na definisanju i opisivanju koraka za uspešno izvođenje pentesta u praksi, NIST *eng. Technical Guide to Information Security Testing and Assessment (NIST SP 800 115)* [13] predstavlja zvanično, zakonski definisano uputstvo za izvođenje penetracionog testa. Predstavlja formalnu, strukturiranu metodologiju koje su prihvatile mnoge federalne agencije i velike kompanije. NIST deli pentesting proces na četiri osnovne faze:

- Planiranje - kreiranje rigorozne dokumentacije testnog plana
- Otkrivanje - koristeći aktivno skeniranje sa prikupljanjem javno dostupnih informacija, sa osvrtnom na ručnu potvrdu pronađenih informacija
- Napad - kontrolisana eksploatacija bezbednosnih propusta unutar unapred određenih, striktnih bezbednosnih ograničenja
- Izveštaj - izveštaj namenjen klijentima kao i tehničkoj publici, sa jasnim smernicama za otklanjanje problema [5].

2.2.3 Open Source Security Testing Methodology Manual

OSSTMM (*eng. Open Source Security Testing Methodology Manual - OSSTMM*) vodi testiranje kroz pet kanala da bi se utvrdilo koliko zaista funkcionišu bezbednosni procesi. Na taj način možemo da saznamo šta se operacije postižu pored toga šta je nama cilj da one postignu. Tih pet kanala su:

- **Ljudska bezbednost** - procena bezbednosti u međuljudskim interakcijama i komunikaciji
- **Fizička bezbednost** – rigorozno testiranje fizičkih aspekata bezbednosti koji zahtevaju fizički pristup.
- **Bežične komunikacije** - ispitivanje elektronskih kanala i komunikacija.
- **Telekomunikacije** - evaluacija digitalnih i analognih telekomunikacionih mreža.
- **Mreže za prenos podataka** - testiranje elektronskih sistema i mreža koje se koriste za komunikaciju. [15]

OSSTMM smatra da ovih pet područja zahteva posebnu pažnju što se tiče bezbednosti. Na ove kanale se primenjuje pentesting da bi se otkrile slabosti i ranjivosti sistema. [15]

2.2.4 Open Web Application Security Project

OWASP (eng. *Open Web Application Security Project* - **OWASP**) je organizacija koja se bavi bezbednošću softvera kroz projekte otvorenog koda. Ova organizacija zastupa da se bezbednosne kontrole trebaju primenjivati na više nivoa, kako bi se obezbedila slojevitost zaštita od napada kroz više uzastopnih testiranja. Vršiti se modelovanje pretnji, pregled koda, skeniranje ranjivosti, pentesting. Cilj je pronalaženje slabosti. Metodologija je fleksibilna i prilagodljiva okruženjima i zahtevima. Služi za izradu programa za testiranje bezbednosti.

- **Planiranje i priprema** - pregled servera i aplikacija, prikupljanje informacija za naredne faze, definišu se ciljevi, pretnje i ranjivosti.
- **Modeliranje pretnji** – pravi se model web aplikacije. Prepoznaju se pretnje i procenjuje se verovatnoća da se one dogode. Poznata je infrastruktura aplikacije i njen uticaj na bezbednost i kako ona može biti zloupotrebljena.
- **Procena ranjivosti** - koriste se automatski alati i ručno testiranje za uočavanje uobičajenih propusta. Ispituju se nalozi, pristupi i privilegije, kao i proces kreiranja i brisanja naloga.
- **Sanacija** - ranjivosti se dele po prioritetu ozbiljnosti radi izrade bolje strategije za rešavanje.
- **Verifikacija** - nakon otklonjenih ranjivosti sve se ponovo testira da bi se potvrdila efikasnost rešenja.
- **Održavanje** - neophodno je redovno praćenje što znači ažuriranje bezbednosnih kontrola i često sprovođenje provera ranjivosti. Tim za održavanje trebalo bi da bude upućen u prethodno sprovedena rešenja. Vodi se evidencija rezultata dobijenih procesima testiranja radi održavanja [18].

3 Alati korišćeni u penetracionom testiranju i eskalacija privilegija

3.1 Alati korišćeni u penetracionom testiranju

Pentesting alati se koriste kao deo penetracionog testiranja kako bi se određeni procesi automatizovali, povećala efikasnost testiranja kao i za otkrivanje ranjivosti sistema koje je teško otkriti manuelnom analizom. Neki od tipova pentesting alata su sledeći:

- **Port Scanners** - otkrivaju otvorene portove unutar nekog sistema. Otvoreni portovi sugerišu koji vektori napada se dalje mogu koristiti na tom sistemu kao i neke dodatne informacije o sistemu.
- **Vulnerability Scanning** - traže se poznate slabosti sistema, kao i loša konfiguracija koja može biti zloupotrebljena od strane napadača.
- **Network Sniffers** - alati koji slušaju mrežni saobraćaj. Korisno prilikom identifikacije da li su podaci u saobraćaju enkriptovani, kao i da se identifikuju potencijalno nebezbedne putanje komunikacije.

- **Web Proxies** - tester i uz pomoć veb proksija mogu uticati i menjati saobraćaj između pretraživača i veb servera kompanije.
- **Password Cracking** - napadom grube sile korisničkih šifara unutar sistema je jedan od najčešćih sajber napada. Omogućava testeru da zaključi da li zaposleni unutar kompanije koriste slabe ili jake lozinke [1] .

3.2 Eskalacija privilegija

Eskalacija privilegija (eng. *Privilege escalation*) predstavlja dobijanje neautorizovanog pristupa nad osetljivim resursima određenog sistema zloupotrebljavajući bagove, lošu konfiguraciju operativnog sistema ili softvera.

Dva tipa eskalacije privilegija su sledeća:

- **Horizontalna eskalacija privilegija** - napadač siri svoje privilegije tako što preuzima drugi nalog i preuzima legitimne privilegije dodeljene tom korisniku.
- **Vertikalna eskalacija privilegija** - napadač pokušava da preuzme druge privilegije sa nalogom na kom se već nalazi. Npr. napadač se nalazi na regularnom nalogu korisnika, ali pokušava da dobije privilegije administratora ili root-a. [19]

Za napadače eskalacija privilegija znači pristup okruženju, nadzor i dubina pristupa kao i druge zlonamerne aktivnosti. Povećanje privilegija otvara napadaču širok spektar novih napada na ciljani sistem. Na primer, sticanje pristupa drugim povezanim sistemima, raspoređivanje dodatnih zlonamernih zahteva na ciljani sistem, izmena bezbednosnih postavki ili privilegija, dobijanje pristupa aplikacijama ili podacima unutar sistema koji su van privilegija prvobitno kompromitovanog naloga. U ekstremnim situacijama dobijanje pristupa root-u sistema ili čitavoj mreži. Ako bezbednosni tim sumnja na moguću eskalaciju privilegija neophodno je da se odradi sveobuhvatno istraživanje čitavog sistema. Znači da je došlo do eskalacije privilegija na sistemu su malver (eng. *malware*), sumnjiva logovanja i sumnjiv mrežni saobraćaj.

Povećanje privilegija tipično uključuje eksploataciju ranjivosti kao što su softverski bagovi, loša konfiguracija i pogrešne kontrole pristupa. Svaki nalog koji komunicira sa sistemom ima određene privilegije.

Standard koji se koristi su uglavnom ograničen pristup bazama podataka, osetljivim fajlovima ili resursima. U nekim slučajevima, korisnici imaju visok nivo pristupa osetljivim resursima, a da nisu ni svesni toga zato što ni ne pokušavaju da dobiju pristup van svojih predviđenih prava pristupa. U drugim slučajevima, napadači mogu da manipulišu slabostima sistema da povećaju privilegije. Ukoliko se inicijalno dobije pristup nalogu niskog nivoa, zlonamerni napadač neće odmah imati pristup ostatku sistema ali svakako ima ulaznu tačku. Napadači će vršiti nadzor sistema dok ne nađu tačku unutar sistema uz pomoć koje će eskalirati dalje privilegije. U zavisnosti od cilja, napadači će nastaviti da horizontalno šire svoju inicijalnu kontrolu nad sistemom ili će vertikalno širiti privilegije da bi dobili nivo kontrole admina ili root-a kako bi kao krajnji cilj dobili pristup nad čitavim okruženjem. [4]

Vektori napada koje napadači koriste kako bi došlo do eskalacije privilegija:

- **Eksploatacija kredencijala** - Jednofaktorska autentikacija[11] je najnebezbednija provera kredencijala korisnika i ostavlja praktično otvorena vrata napadačima za

eskalaciju privilegija ukoliko dođu do kredencijala. Čak i ukoliko dođe do detekcije neautorizovanog pristupa sistemu, napadač ima više načina kako da dođe i do resetovane lozinke. Neki od najčešćih načina za vraćanja prvobitnih kredencijala su:

- **Password Exposure** - pronalaženje šifre među deljenim fajlovima unutar kompanije
 - **Password guessing** - na osnovu javno dostupnih informacija o korisniku napadač može da logički pogađa koja je korisnikova lozinka.
 - **Shoulder surfing** - posmatranje aktivnosti žrtve ili uživo ili putem neautorizovanog pristupa kamerama ili preko keyloggera na njihovim uređajima.
 - **Dictionary attacks** - na osnovu učestalih reči kreiraju se potencijalne šifre korisnika koje se potom redom isprobavaju dok se ne nađe šifra.
 - **Rainbow table attacks** - na osnovu već učestalih šifara (na osnovu prethodnih data breacheva) kreiraju se rainbow tabele koje su sačinjene od heš tabela učestalih šifara koje se onda potom redom isprobavaju na targetiranom sistemu dok se ne nađe pogodak.
 - **Brute force password attacks** - najčešće poslednja opcija za napad jer je eskponencijalne složenosti. Kreira se svaka moguća kombinacija slova, brojeva i specijalnih karaktera počevši od dužine jedan dok se ne nađe pogodak [4].
- **Ranjivosti i eksploati** - Napadači mogu da izvrše eskalaciju privilegija eksploatacijom ranjivosti dizajna, implementacijom ili konfiguracijom sistema. Ovo uključuje protokole i putanje komunikacije na mreži, operativne sisteme, brauzere, veb aplikacije, klad sisteme i mrežnu infrastrukturu. Nivo rizika zavisi od prirode ranjivosti i koliko je kritičan sistem u kome se ta ranjivost nalazi. Samo mali broj ranjivosti dozvoljava vertikalno širenje privilegija. Svaka ranjivost koja dozvoljava napadaču da menja privilegije treba biti tretirana sa velikom ozbiljnošću [4].
 - **Loša konfiguracija** - povećanje privilegija najčešće proizilazi iz loše konfiguracije kao što je neuspešna konfiguracija prisupa osetljivim delovima sistema, greške u firewall-u ili otvoreni portovi [4].
 - **Malver** - napadači mogu da koriste bilo koji tip malvera kao što su trojanci, spajver, kompjuterski crvi i ransomware da bi pridobili okruženje i izvršili eskalaciju privilegija. Malver može biti ubačen zbog zloupotrebe ranjivosti sistema, može biti upakovan u legitimne aplikacije usled korišćenja sumnjivih linkova u kombinaciji sa socijalnim inženjeringom. Malver predstavlja zlonamerni proces koji se odvija na operativnom sistemu i ima dozvole sa naloga korisnika koji ga je uneo u sistem. Postoje dve putanje eksploatacije:
 - Napadači koji pridobiju pristup korisnikovom nalogu mogu da unesu malware na nivou korisnika i onda pronađu način da prošire svoje privilegije.
 - Napadač već ima visok stepen privilegija, unosi malver na nivou admina ili root-a i koristi ga da zadži pristup celom okruženju.
 - **Socijalni inženjering** - Socijalni inženjering se koristi skoro u svim sajber napadima. On se zasniva na manipulaciji ljudima da bi se narušile bezbednosne procedure i pridobile osetljive ili lične informacije. Socijalni inženjering je veoma efikasan jer

zaobilazi bezbednosne kontrole oslanjajući se na ljudske slabosti i manipulisanje emocijama. Neki primeri socijalnog inženjeringa koji se često koriste:

- **Phishing** - napadač šalje poruku koja imitira legitimog pošaljioa sa zlonamernim linkom i prilogom. Ako žrtva klikne na link ili otvori prilog, napadač unosi malware i kompromituje uređaj. Zavisno od tipa malvera ovo može da dozvoli napadaču da preuzme korisnikove kredencijale [4].
- **Spear phishing** - sofisticirana verzija phishing-a koja je napravljena za specifično privilegovane korisnike ili grupu korisnika. Spear phishing dozvoljava napadaču da preuzme visoke privilegije naloga kao na primer one koji pripadaju administratorima, zaposlenima u finansijama ili seniorima [4].
- **Vishing** - *voice phishing* ili vishing predstavlja vid socijalnog inženjeringa gde napadač zove zaposlene u kompaniji predstavljajući se kao autoritarna figura (npr, IT radnik u kompaniji, bankar, pravnik) gde od zaposlenog traži poverljive informacije [4].
- **Pharming** - predstavlja napad u kome se korisnik preusmerava sa legitimne internet stranice na lažnu, obično radi krađe ličnih ili finansijskih podataka [4].

4 Zakonski i etički aspekti

4.1 Etički aspekti pentestinga

Autorizacija

Autorizacija se odnosi na eksplicitnu dozvolu od organizacije i individue koja poseduje sistem ili mrežu koja se testira. Bez odgovarajuće autorizacije, tester efektivno učestvuje u neetičkom hakovanju. Održavanje autorizacije je krucijalni korak da se osigura da se pentesting izvodi etički i legalno. Čista dokumentacija testiranja je da se izbegne nesporazumi i osiguravanje da se testiranje održava u kontrolisanim i legalno definisanim uslovima.[7]

Transparentnost

Etički hakeri moraju da budu transparentni sa svojim klijentima oko metodologija, alata i tehnika koje koriste. Ovo znači da ne bi trebalo nijedan aspekt metodologije da drže skrivenu od klijenta. Ova transparentnost je neophodna da osigura da klijenti razumeju kako se testiranje odigrava i da mogu da daju neophodne povratne informacije. Svojom transparentnošću o testiranju, etički hakeri takode grade poverenje kod svojih klijenata koji će imati bolje razumevanje kako se odvija posao i koje su moguće implikacije rezultata. [7]

Poverljivost

Organizacije i tester moraju da osiguraju da podaci sakupljeni tokom testiranja su poverljivo sačuvani i nisu podeljeni sa neautorizovanim stranama. Ovo uključuje korišćenje sigurnih prostora za čuvanje podataka i metode za uništenje podataka tako da se oni ne mogu povratiti. Etički hakeri imaju obavezu da očuvaju poverljivost svega što pronađu. Ne bi trebalo javno da objavljuju informacije o ranjivosti koji mogu dovesti do napada protiv klijenta. Oni informacije mogu da dele samo sa autorizovanim osobljem i osiguraju

da su informacije zaštićene od neovlašćenog pristupa. Moraju da balansiraju otvorenost po pitanju ranjivosti sa potrebom da održe bezbednost svojih klijenata. Ovo zahteva pažljivo razmišljanje i kolaboraciju sa klijentima da ugovore odgovarajuće nivoe otvorenosti i najbolji način da saniraju sve ranjivosti koje su otkrivene[7].

Odgovornost

Organizacije moraju da budu sigurne da se testiranje održava u odgovornom i profesionalnom maniru i da šteta nije naneta njihovim zaposlenima, kupcima ili zainteresovanim tokom procesa. Ovo uključuje implementaciju odgovarajućih sigurnosnih procesa da spreče štetu sistema ili mreže i osiguraju da testiranje ne naruši kritične operacije. Organizacija mora da uzme odgovornost da je adresirala sve otkrivene ranjivosti testiranja tačno. Ovo uključuje prioritizaciju i adresiranje ranjivosti na vreme i na efikasan način da bi se smanjili rizici eksploatacije[7].

4.2 Legalni aspekti pentestinga

Usklađenost

Organizacija mora da osigura da testing vežbe potpadaju pod zakon i regulative, uključujući zakonsku zaštitu podataka, zakon privatnosti i zakon intelektualne svojine[7].

Obaveza

Organizacije moraju da razmišljaju o potencijalnim obavezama koje se mogu pojaviti kao posledica testiranja, kao što je šteta naneta mreži ili sistemu. Ovo može da uključuje građanske i kriminalne obaveze, zavisno od prirode i količine šteta koja je nastala. Da se ove obaveze ublaže, organizacije moraju da osiguraju da učestvuju sa kvalifikovanim testerima od poverenja koji imaju neophodne veštine i iskustvo da se izvrši testiranje. Ovo uključuje verifikaciju kredencijala i praćenje zapisnika testera, kao i da osiguraju da prate etičke standarde i najbolje postupke u poslu. Organizacije moraju da osiguraju da imaju odgovarajuće osiguranje da se zaštite od potencijalnih obaveza koje mogu doći kao posledica testiranja[7].

Dokumentacija

Organizacija mora da vodi detaljan zapisnik svojih testova, uključujući nadgledanje testova, korišćenih metoda i postignutih rezultata. Ova dokumentacija je neophodna da se demonstrira da je organizacija učestvovala na odgovoran i profesionalan način tokom testiranja i da se uklapa u regulative i legalne zahteve. Održavanje detaljnih zapisnika testiranja može da pomogne organizaciji ako se desi da je narušena bezbednost. Podnošenjem dokaza da su preduzeli sve korake da zaštite svoj sistem i mrežu, organizacija može da smanji potencijalne obaveze i minimizuje štetu[7].

Certified Ethical Hacker

CEH (eng. *Certified Ethical Hacker*) je kvalifikacija izdata od strane EC-Council-a i dobija se demonstriranjem znanja o proceni bezbednosti računarskih sistema traženjem ranjivosti u ciljanim sistemima, koristeći ista znanja i tehnike kao zlonamerni napadač,

ali na zakonit i legitiman način. Koristi se za procenu bezbednosnog položaja ciljanog sistema[2].

Offensive Security Certified Professional

OSCP (eng. *Offensive Security Certified Professional*) je etički hakerski sertifikat koji nudi Offensive Security (short. *OffSec*) koje uči potencijalne testing metodologije i koristi alate poput Kali Linux distribucije. Smatra se više tehničkim nego etičkim sertifikatom i jedan je od retkih sertifikata koji traže dokaz o praktičnim sposobnostima praktičnog penetracionog testiranja[14].

5 Trendovi i budućnost ofanzivne bezbednosti

5.1 Purple teaming

Purple team je grupa sajber bezbednosnih profesionalaca koji simuliraju maliciozne napade i pentesting da bi identifikovali ranjivosti i predložili strategije za organizacije u IT infrastrukturi. Izraz je izveden od reci ljubičasto što simbolizuje kombinaciju crveni (ofanzivni) i plavi (defanzivni) tim. Za razliku od tradicionalnog crvenog i plavog tima koji su obično razdvojeni delovi, ljubičasti tim radi u bliskoj koordinaciji, dele informacije i uvid da bi uočili ranjivosti i unapredili sveukupno stanje bezbednosti sistema.

Ljubičasti tim nudi isti benefit kao i crveni i plavi tim. On omogućava organizacijama da aktivno testiraju postojeće sajber bezbednosti i sposobnosti u okruženjima niskog rizika. Ujedinjenje crvenog/plavog tima omogućava organizaciji da identifikuje lošu konfiguraciju i pokriva rupe u postojećim bezbednosnim proizvodima. On ojačava mrežnu bezbednost da detektuju targetirane napade i uspori vreme koje je potrebno napadaču da kompromituje mrežu i raširi se u njoj. Podiže upućenost osoblja u rizike ljudske ranjivosti koji mogu da kompromituju bezbednost organizacije. Ujedinjenje crvenog i plavog tima kao jednu jedinicu nudi dodatne benefite kao što je povećanje zaštite kroz konstantan feedback i znanje podeljeno izmedju ujedinjenog ofanzivnog i defanzivnog tima. Konstantno testiranje preneseno kroz konstantno angažovanje ljubičastog tima. Plavi i crveni tim imaju zajedničke ciljeve [12].

5.2 AI u pentesting napadima i odbrani

AI pentestiranje obezbeđuje bezbednost veštacke inteligencije sistema tako što simulira napade koji eksploatišu njihove ranjivosti. Za razliku od tradicionalnog pentestinga koji se fokusira na mrežu, aplikacije i infrastrukturu, AI pentesting otkriva slabosti u AI modelima arhitekture, rada sa podacima i procesom donošenja odluke. AI pentesting pomaže u identifikovanju ranjivosti koje mogu da dozvole hakerima da isfiltriraju osetljive podatke. Ovaj pristup otvara AI model mnogim potencijalnim napadima [8].

- **Trovanje podataka** U ovoj vrsti napada, haker ubacuje zlonamerne podatke u kolekcije podataka za treniranje, korumpirajući model za proces učenja. Kao rezultat, AI sistem prihvata netačne šablone i ponašanja, kompromitujući pouzdanost njegovih izlaza. Validacija podataka i anomalije detektovane pomažu zaštititi treniranih podataka da identifikuju i filtriraju sumnjive ili izmanipulisane ulaze [8].
- **Prompt injection napad** Ovo se dešava kada napadači koriste manipulativne prompt-ove da generisu štetan sadržaj, kao što je zlonamerni kod ili diskriminišući

jezik. AI pentesting će naći te probleme koji mogu biti popravljani kroz striktnu ulaznu validaciju i korisničku autentifikaciju [8].

- **Inverzija modela i ekstrakcija podataka** Maliciozni akteri izvršavaju inverziju modela kako bi rekonstruisali osetljive podatke ili replikovali model. Ako uspeju, ova zloupotrebljena ranjivost daje napadaču pristup ličnim podacima [8].

6 Zaključak

Penetraciono testiranje je autorizovani i kontrolisani pokušaj otkrivanja i iskorišćavanja bezbednosnih ranjivosti kako bi se unapredila zaštita sistema. Testovi se dele po nivou informacija koje tester ima (black/gray/white-box) i po ciljanoj oblasti (mreža, web aplikacije, bežične mreže, socijalni inženjering itd.). Postoje standardizovane metodologije (npr. PTES, OWASP, OSSTMM) koje strukturiraju faze od pre-angažovanja i izviđanja do eksploatacije i izveštavanja. Eskalacija privilegija obuhvata vertikalnu (podizanje prava), horizontalnu (pristup drugim korisničkim nalogima), kao i lokalne i udaljene tehnike koje omogućavaju održavanje pristupa. U etičkom i pravnom kontekstu, ključni su pisani autoritet (saglasnost), jasno definisan obim i pravila, minimalna šteta tokom testa i detaljan izveštaj sa preporukama za sanaciju.

Literatura

- [1] HackerOne Knowledge Center. „Pentesting Tools You Must Know About”. U: (). Accessed: 2025-10-30. URL: <https://www.hackerone.com/knowledge-center/7-pentesting-tools-you-must-know-about>.
- [2] „Certified Ethical Hacker”. U: (). Accessed: 2025-10-30. URL: https://en.wikipedia.org/wiki/Certified_ethical_hacker.
- [3] Cycognito. „Defensive Security”. U: *Cycognito* (2025.). Accessed: 2025-10-30. URL: <https://www.cycognito.com/glossary/defensive-security.php>.
- [4] Cynet. „Understanding Privilege Escalation and 5 Common Attack Techniques”. U: (2025.). Accessed: 2025-10-30. URL: <https://www.cynet.com/network-attacks/privilege-escalation/>.
- [5] Deepstrike. „Penetration testing methodologies”. U: (). Accessed: 2025-10-30. URL: <https://deepstrike.io/blog/penetration-testing-methodology>.
- [6] GeeksForGeeks. „Penetration Testing Execution Standard (PTES)”. U: *PTES* (2025.). Accessed: 2025-10-30. URL: <https://www.geeksforgeeks.org/software-engineering/penetration-testing-execution-standard-ptes/>.
- [7] Jason Gillam. „What are the ethical and legal considerations for penetration testing?” U: (). Accessed: 2025-10-30. URL: <https://www.secureideas.com/knowledge/what-are-the-ethical-and-legal-considerations-for-penetration-testing>.
- [8] Fergal Glynn. „AI Penetration Testing: The 3 Biggest Vulnerabilities”. U: (2025.). Accessed: 2025-10-30. URL: <https://mindgard.ai/blog/ai-penetration-testing-biggest-vulnerabilities>.
- [9] IBM. „Offensive Security”. U: *IBM* (2025.). Accessed: 2025-10-30. URL: <https://www.ibm.com/think/topics/offensive-security>.
- [10] IBM. „Penetration testing methodologies and standards”. U: *IBM* (2025.). Accessed: 2025-10-30. URL: <https://www.ibm.com/think/insights/pen-testing-methodology>.
- [11] LoginNc. „Types of Authentication”. U: (). Accessed: 2025-10-30. URL: <https://www.logintc.com/types-of-authentication/single-factor-authentication/>.
- [12] Janani Nagarajan. „What is a Purple Team?” U: (2023.). Accessed: 2025-10-30. URL: <https://www.crowdstrike.com/en-us/cybersecurity-101/advisory-services/purple-teaming/>.
- [13] „NIST SP 800-115”. U: (2021.). URL: <https://www.nist.gov/privacy-framework/nist-sp-800-115>.
- [14] „Offensive Security Certified Professional”. U: (). Accessed: 2025-10-30. URL: https://en.wikipedia.org/wiki/Offensive_Security_Certified_Professional.
- [15] Kirk Patrick Price. „OSSTMM”. U: (2023.). Accessed: 2025-10-30. URL: <https://kirkpatrickprice.com/blog/what-you-need-to-know-about-osstmm/>.
- [16] PTES. „PTES”. U: *PTES* (2025.). Accessed: 2025-10-30. URL: http://www.pentest-standard.org/index.php/Main_Page.
- [17] RedScan. „Types of penetration testing”. U: (2024.). Accessed: 2025-10-30. URL: <https://www.redscan.com/news/types-of-pen-testing-white-box-black-box-and-everything-in-between/>.
- [18] Sapphire.net. „OWASP Methodology Security Testing Phases”. U: (). Accessed: 2025-10-30. URL: <https://www.sapphire.net/blogs-press-releases/owasp-methodology/>.

- [19] Joshua Selvidge. „Privilege Escalation Attacks: Types, Examples, And Prevention”. U: (2024.). Accessed: 2025-10-30. URL: <https://purplesec.us/learn/privilege-escalation-attacks/>.
- [20] SentinelOne. „Red Team vs. Blue Team: What’s The Difference?” U: (). Accessed: 2025-10-30. URL: <https://www.sentinelone.com/cybersecurity-101/cybersecurity/red-team-vs-blue-team/>.